

Executive Data Safety Guarantee:

Google Drive MCP operates under a strict **Zero-Persistence Architecture**. Your personal files, document bodies, spreadsheets, slide presentations, folders, and Google Drive contents are **NEVER saved, written to disk, indexed, cached, or harvested** on our servers.

1. Overview & Operational Security Model

Google Drive MCP functions as a secure, ephemeral bridge between ChatGPT / AI Agents and your authorized Google Drive account. When an AI tool reads, searches, or downloads a document at your command, data streams directly through volatile runtime memory (RAM) over encrypted TLS/HTTPS and is **immediately released and purged from memory** once forwarded to your chat session.

2. The Five Pillars of User Data Protection

**1. Zero File Content Persistence**

No file contents ever touch persistent disk storage, databases, or local file caches. Content is streamed with an enforced **10 MB memory ceiling**; if exceeded, the stream is aborted immediately.

**2. Complete Multi-User Cryptographic Isolation**

Every user authenticates their own individual Google Account. Internal opaque subjects (`usr_...`) isolate every request. User A can never discover, read, modify, or delete User B's files.

**3. AES-256-GCM Credential Encryption at Rest**

OAuth tokens are protected using military-grade AES-256-GCM authenticated encryption with 96-bit random IVs and 128-bit authentication tags. Stored with restricted OS mode `0600`.

**4. Strict OAuth 2.0 with Mandatory PKCE S256**

Full RFC 7636 PKCE S256 enforcement prevents interception and code injection. Single-use authorization codes, refresh token rotation, and constant-time comparisons stop replay and side-channel attacks.

3. What Is Stored vs. What Is Never Stored

Data Category	Stored?	Protection Method	Retention Policy
Google Drive File Contents (Docs, Sheets, PDFs, Text, Binary)	NEVER STORED	Volatile RAM only, 10 MB limit, immediate memory purge	Ephemeral (Discarded immediately upon HTTP response completion)
User File Metadata & Directory Tree	NEVER STORED	Streamed on-demand from Google Drive API	Zero persistent caching; fetched live per request
User Google Account Passwords	NEVER STORED	Google OAuth 2.0 (Password never shared with MCP)	Handled exclusively by Google's authentication servers
OAuth Access & Refresh Tokens	STORED ENCRYPTED	AES-256-GCM + POSIX 0600 restricted permissions	Until user disconnects or revokes Google account authorization
OAuth Linking State & Challenge Codes	EPHEMERAL ONLY	Hashed SHA-256, atomic single-use consumption	Purged immediately after single use or expired after 10 minutes
Audit Logs & Telemetry	REDACTED LOGS	Deep sanitization (Redacts tokens, secrets, keys, paths)	No file contents or credentials ever enter log files

4. Total User Control & Instant Revocation

You maintain absolute ownership and control over your Google account credentials at all times:

Two Instant Ways to Disconnect & Purge Your Credentials:

- Inside ChatGPT:** Ask ChatGPT to disconnect your Google Drive. The MCP server automatically revokes tokens with Google and permanently deletes your encrypted credentials from disk.
- Directly via Google Account:** Visit [Google Account Security → Third-Party Apps](#) and revoke access instantly. All future API requests fail immediately and trigger an automatic local credential purge.

5. Multi-User Isolation & Identity Binding

- In a shared MCP environment, cross-account data leakage is a critical threat. Google Drive MCP enforces multi-layer isolation:
- Opaque Cryptographic Identity:** When connecting via OAuth, the server assigns a random internal identifier (e.g. `usr_9c16...`). This opaque subject cannot be forged or manipulated.
 - Client Argument Sanitization:** Client requests attempting to inject a custom `userId` or `userSub` parameter are stripped and ignored before argument parsing. Identity is derived strictly from the verified Bearer token.
 - Per-User API Clients:** Every Google Drive, Docs, Sheets, and Slides API call instantiates an isolated client instance loaded with credentials belonging exclusively to the caller.

6. Military-Grade Credential Encryption at Rest (SEC-04)

Credential stores are encrypted using **AES-256-GCM** (Galois/Counter Mode) authenticated encryption:

**256-Bit Master Key**

Key is supplied via environment variable (`STORAGE_ENCRYPTION_KEY`), never committed to Git, and validated on server boot.

**Unique 96-Bit Nonce**

Every file write generates a fresh, cryptographically random Initialization Vector (IV), preventing ciphertext pattern analysis.

**128-Bit Tamper Tag**

GCM authentication tag guarantees cryptographic integrity. Any unauthorized byte modification immediately causes a fail-closed rejection.

7. Destructive Operations & Deletion Safeguards (SEC-05)

Accidental or runaway data destruction is prevented through architectural guardrails:

Destructive Guardrails & Non-Retry Enforcement:

- Trash vs. Permanent Delete Separation:** Standard deletion moves files to trash (`drive_trash_file`), allowing recovery. Permanent deletion (`drive_delete_file_permanently`) is a separate tool with explicit warnings and `destructiveHint: true`.
- Zero Automatic Retries (SEC-05):** Unlike read operations which retry transient network drops (HTTP 503), permanent deletion enforces `maxAttempts: 1`. A dropped network packet or server hiccup will **never cause a second deletion attempt**.
- Strict Single-Target Scope:** Permanent delete operates only on an explicit single `fileId`. Wildcards, directory recursion, batch delete, and bulk deletion commands are strictly forbidden.
- Safe File Restoration:** Restoring files (`drive_restore_file`) is fully idempotent; restoring an active file succeeds harmlessly without altering metadata.

8. Google Workspace File Integrity Guardrails (DRV-03)

- Native Google Docs, Sheets, and Slides have complex proprietary schemas. Directly uploading raw text/binary to a native Google Doc corrupts the document on Google Drive.
- Direct Overwrite Interception:** `[drive_update_file]` performs pre-flight inspection of target MIME types. If the target is a native Google Doc, Spreadsheet, or Presentation, direct overwriting is blocked with explanatory guidance.
 - Dedicated Structured Tools:** Modifications to spreadsheets and slides must use dedicated tools (`drive_sheet_update_range`, `drive_sheet_append_rows`, `drive_slides_update`) that preserve document structure.

9. Download & Export Safety (DRV-01, DRV-02)

**Binary-Safe MIME Handling**

Files are classified using extensive MIME and extension heuristics. Binary files (PDF, PNG, ZIP, DOCX, XLSX) are encoded in Base64; text files are encoded in UTF-8, preventing file corruption.

**Validated Workspace Exports**

Exporting Google Docs/Sheets/Slides validates targets against a strict whitelist (e.g. Doc → PDF/DOCX; Sheet → CSV/XLSX). Arbitrary or invalid export formats are rejected before API calls.

10. Permission Governance & Sharing Guardrails

- File sharing and permission management within Google Drive follow the principle of least privilege:
- Ownership Transfer Strictly Blocked:** Any tool call attempting to grant or transfer the `owner` role is rejected with an explicit security violation error (`OWNERSHIP_TRANSFER_BLOCKED`).
 - No Anonymous/Public Write Access:** Permissions tools require explicit recipient identification (email address for user/group or domain name for domain sharing). Anonymous public writes cannot be created.
 - Granular Roles:** Permissions are restricted to verified roles: `reader` , `commenter` , or `writer` .

11. Advanced Search Safety & Injection Protection

- Google Drive API query strings (`q` parameter) can be vulnerable to query injection if user input is improperly formatted:
- Query Escaping:** All structured filter fields (name, owner email, parent folder ID, full-text terms) undergo strict escaping of backslashes (`\\`) and single quotes (`\'`).
 - ISO-8601 Date Validation:** Date filters (`modified_after` , `created_before` , etc.) are parsed through JavaScript Date validators. Any malformed date string throws `INVALID_DATE_FORMAT` before building queries.

12. Memory Bounds & Denial of Service Protection

**10 MB Stream Boundary**
If any file download or read operation exceeds 10 MB, the upstream stream is destroyed immediately and memory buffers are freed.

**30-Second API Timeout**
All Google API network calls are governed by hard 30,000ms timeouts, preventing hanging background processes.

**Bounded Pagination**
Collection endpoints (search, folder listing, permissions) enforce maximum limits (100 to 1,000 items) to prevent unbounded memory growth.

13. Deep Privacy Sanitization & Redaction

- The server maintains comprehensive audit logging for security monitoring, but implements deep, recursive redaction to guarantee zero secret leakage:
- Token Redaction:** Google access tokens (`ya29.*`), refresh tokens (`1/*`), client secrets, encryption keys, and one-time link codes (`glink_*`) are automatically replaced with `[REDACTED]` .
 - Filesystem Privacy:** Internal server filesystem paths (e.g. `/Users/...` or `/home/...`) and stack traces are stripped from client-facing errors.
 - No File Data in Logs:** Content payloads, document text, and base64 binaries are never logged in audit files.

14. Rate Limiting & Abuse Controls

**Per-User Tool Call Limiter**
Authenticated MCP sessions are capped at **60 tool calls per minute** per user, preventing unintended tool loops or API quota depletion.

**JSON-RPC Batch Ceiling**
Batch requests are capped at a maximum of **10 operations per batch**, preventing batch-stuffing denial of service attacks.

15. Complete Security Verification Summary

Security Domain	Standard / Requirement	Implementation Mechanism	Status
Data Storage	Zero Content Retention	Volatile RAM streaming; zero file persistence on disk or database	VERIFIED
Tenant Isolation	Multi-User Segregation	Opaque userSub + parameter injection stripping + per-user Google clients	VERIFIED
At-Rest Encryption	NIST SP 800-38D	AES-256-GCM + 96-bit random IV + 128-bit auth tag + POSIX 0600 mode	VERIFIED
OAuth Protocol	RFC 6749 & RFC 7636	Mandatory PKCE S256 + constant-time comparison + HTTPS redirect allowlist	VERIFIED
Destructive Safety	Irreversibility Protection	maxAttempts: 1 on delete (SEC-05) + single fileld scope + trash separation	VERIFIED
File Integrity	Format Preservation	DRV-03 Workspace overwrite block + DRV-01 binary/text MIME routing	VERIFIED
Rate & Abuse	DoS & Loop Protection	60 req/min per user + 10-item batch cap + 10 MB memory ceiling	VERIFIED